

MÉMOIRE DE VEILLE TECHNOLOGIQUE

LeadDev M1/M2I Promotion 2026

Sujet 6

Confidential Computing et Trusted Execution Environments : promesses, limites et réalités opérationnelles

Problématique :

Le Confidential Computing protège-t-il vraiment les données sensibles en production, ou crée-t-il une fausse confiance à un coût d'intégration dissuasif ?

Invité podcast : Anès Ayad, CEO & Fondateur, Net Protect

1. Synthèse

Le Confidential Computing désigne l'ensemble des technologies permettant de protéger des données en cours d'utilisation c'est-à-dire en mémoire vive pendant leur traitement grâce à des zones d'exécution isolées au niveau matériel, appelées Trusted Execution Environments (TEE). Contrairement au chiffrement classique qui protège la donnée au repos ou en transit, les TEE garantissent que même l'infrastructure hôte ne peut pas accéder au contenu des données pendant leur traitement.

Contexte

Le Confidential Computing via les Trusted Execution Environments (TEE) propose une réponse matérielle au problème fondamental de confiance dans l'infrastructure cloud : traiter des données sensibles sans exposer leur contenu, même au fournisseur cloud, à l'hyperviseur ou à l'administrateur système. Ce mémoire examine si cette promesse tient en conditions réelles de production, à quel coût d'intégration elle s'accompagne, et quels risques subsistent lorsque la technologie est mal implémentée ou mal comprise.

1.1 Hypothèses et résultats

Hypothèse	Ce que nous cherchons à prouver	Résultat	Confiance
H1 : Les TEE répondent à de vraies contraintes métier, indépendamment des seules obligations réglementaires	Des cas d'usage concrets justifient l'adoption sans obligation directe : authentification forte, traitement de données médicales, calcul collaboratif inter-organisations	Partiellement confirmée	Moyen : retour terrain qualitatif, biais de sélection possible
H2 : Les principaux freins sont la complexité d'intégration et le coût, davantage que les performances	Le coût one-shot (intégration, portage) et le coût récurrent (maintenance, TCB recovery) sont les obstacles réels, estimés à 2-3x un déploiement standard	Confirmée	Élevé : données terrain + benchmark peer-reviewed
H3 : Les enclaves mal implémentées ou non auditées créent une fausse confiance : le périmètre de menace se déplace, il ne disparaît pas	Une attestation non vérifiée ou un code non audité expose autant qu'une absence de TEE. SGX protège contre l'hyperviseur, pas contre les vulnérabilités dans le code embarqué	Confirmée	Élevé : CVE documentés + confirmation terrain indépendante

1.2 Recommandation opérationnelle

Si j'étais Lead Dev

Je déploierais du Confidential Computing uniquement si le modèle de menace inclut explicitement un adversaire infrastructure fournisseur cloud, administrateur système, hyperviseur compromis. Pour tout autre vecteur d'attaque (injection, RCE, CVE applicatifs, ingénierie sociale), les TEE ne sont pas le bon outil et leur coût d'intégration n'est pas justifié.

Je ne déploierais en aucun cas sans audit préalable de l'implémentation de l'attestation : c'est le point de défaillance le plus fréquent en production selon les retours terrain. Je budgéterai le coût total d'ownership dès le départ intégration, maintenance, renouvellement du parc matériel compatible en anticipant un ratio de 2 à 3 fois le coût d'un déploiement standard.

Enfin, je commencerais par l'attestation avant de déployer l'enclave : maîtriser le mécanisme de preuve avant de déployer la solution est la recommandation centrale qui ressort de cette veille.

2. Introduction

2.1 Contexte et enjeux

La souveraineté des données est devenue un enjeu stratégique majeur pour les organisations qui traitent des informations sensibles dans des environnements cloud. Les garanties contractuelles offertes par les fournisseurs cloud politique de confidentialité, certifications, accords de niveau de service ne constituent pas des garanties techniques. Un administrateur système disposant des droits adéquats peut accéder à la mémoire vive d'une machine virtuelle en cours d'exécution. Un fournisseur cloud soumis à une injonction judiciaire (Cloud Act américain, par exemple) peut être contraint de produire des données hébergées sur ses infrastructures, y compris des données chiffrées au repos si les clés de chiffrement sont également stockées chez lui.

Ce contexte a conduit à l'émergence du Confidential Computing comme réponse technique à la question : peut-on traiter des données sensibles dans une infrastructure dont on ne contrôle pas l'administration, avec la garantie que personne dans cette infrastructure y compris le fournisseur ne peut accéder au contenu des données pendant leur traitement ?

La réponse apportée par les TEE est positive en principe, mais conditionnelle en pratique. C'est ce que cette veille cherche à évaluer.

2.2 Périmètre de la veille

Cette veille couvre les trois grandes implémentations matérielles de TEE disponibles en environnement cloud : Intel SGX (Software Guard Extensions), AMD SEV-SNP (Secure Encrypted Virtualization Secure Nested Paging) et Intel TDX (Trust Domain Extensions). Elle n'aborde pas ARM TrustZone, qui cible principalement les environnements embarqués et mobiles, ni les TEE logiciels (OP-TEE), dont les garanties de sécurité sont fondamentalement différentes.

La veille s'appuie sur trois types de sources : la littérature académique peer-reviewed (benchmarks, analyses de vulnérabilités), la documentation officielle des éditeurs et standards (Intel, CCC, CNCF), et un retour d'expérience terrain obtenu via l'interview d'Anès Ayad, CEO et fondateur de Net Protect, cabinet spécialisé en réseaux et sécurité informatique.

2.3 Questions directrices

Trois questions structurent cette veille et correspondent aux trois hypothèses :

1. Les TEE répondent-ils à de vraies contraintes métier, ou leur adoption est-elle principalement contrainte par les obligations réglementaires ?
2. Quels sont les vrais obstacles à l'adoption du Confidential Computing en production, et comment se comparent le coût d'intégration et le coût de performance ?
3. Les enclaves TEE déployées sans expertise ni audit créent-elles une fausse confiance ? Le périmètre de menace disparaît-il ou se déplace-t-il ?

3. État de l'art

3.1 La donnée en trois états et le problème non résolu

La sécurité des données repose traditionnellement sur la protection de deux états : la donnée au repos (chiffrée sur disque, via AES-256 ou équivalent) et la donnée en transit (chiffrée sur le réseau, via TLS). Ces deux mécanismes sont aujourd'hui matures, largement déployés et bien compris.

Il existe cependant un troisième état, longtemps ignoré faute de solution technique satisfaisante : la donnée en cours d'utilisation, c'est-à-dire en mémoire vive pendant son traitement par le processeur. Dans cet état, la donnée est en clair déchiffrée pour être traitée et donc accessible à quiconque dispose d'un accès à la mémoire du système : un administrateur avec les droits adéquats, un hyperviseur, un processus concurrent malveillant, ou un fournisseur cloud sous injonction judiciaire.

« C'est super puissant. Après, il n'y a pas grand-chose qui offre ça aujourd'hui. » — Anès Ayad, CEO Net Protect, podcast MVT 2026

Le Confidential Computing adresse spécifiquement ce troisième état. Selon le CCC Whitepaper v1.3, il désigne « la protection des données en cours d'utilisation par l'exécution du calcul dans des environnements d'exécution de confiance basés sur le matériel ». C'est une définition précise et délimitée : le CC ne prétend pas résoudre tous les problèmes de sécurité, mais un problème spécifique jusque-là sans solution technique.

3.2 Historique et évolution des TEE

Les premières implémentations commerciales de TEE remontent aux années 2010. Intel a lancé SGX en 2015 avec la génération Skylake de ses processeurs. ARM TrustZone, présent dans les processeurs mobiles depuis 2004, constitue une implémentation antérieure mais avec une granularité et des cas d'usage différents.

La première génération de SGX (v1) souffre d'une contrainte architecturale majeure : l'Enclave Page Cache (EPC), la mémoire sécurisée accessible à l'enclave, est limitée à 128 Mo. Toute donnée dépassant cette limite doit être échangée avec la RAM standard via un mécanisme de chiffrement/déchiffrement à la volée, ce qui génère une dégradation significative des performances sur les charges de travail importantes. SGX v2, introduit avec la génération Ice Lake, lève cette contrainte en supportant jusqu'à 1 To de mémoire sécurisée.

AMD a introduit SEV (Secure Encrypted Virtualization) en 2016, avec une approche différente : au lieu d'isoler des processus individuels (comme SGX), SEV chiffre la mémoire d'une VM entière. SEV-ES (2019) ajoute la protection des registres CPU, et SEV-SNP (2021) ajoute l'intégrité mémoire et la protection contre les attaques de replay. C'est SEV-SNP qui constitue aujourd'hui la référence pour les VM confidentielles en cloud.

Intel TDX, lancé en 2022, adopte la même approche que SEV-SNP : protection au niveau VM plutôt qu'au niveau processus. TDX est disponible sur les processeurs Sapphire Rapids (4e génération Xeon Scalable) et est déployé sur GCP et Azure depuis 2023.

Technologie	Éditeur	Année	Granularité	Mémoire sécurisée	Disponibilité cloud
Intel SGX v1	Intel	2015	Processus (enclave)	128 Mo (EPC)	Azure, AWS (Nitro)
Intel SGX v2	Intel	2021	Processus (enclave)	Jusqu'à 1 To	Azure
AMD SEV-SNP	AMD	2021	VM entière	Mémoire VM complète	Azure, GCP, AWS
Intel TDX	Intel	2022	VM entière (Trust Domain)	Mémoire VM complète	Azure, GCP
ARM TrustZone	ARM	2004	Monde sécurisé / monde normal	Variable	Embarqué / mobile

3.3 L'attestation : le mécanisme de preuve central

L'attestation à distance (remote attestation) est le mécanisme qui permet à une enclave de prouver à un tiers distant qu'elle s'exécute bien dans un TEE intègre et que le code qui tourne est bien celui attendu. C'est le pilier de confiance du Confidential Computing.

Le processus fonctionne de la manière suivante : le CPU génère une « quote » un rapport cryptographiquement signé par une clé ancrée dans le hardware contenant une mesure cryptographique (hash) du code chargé dans l'enclave. Un tiers (le client, un service de vérification) peut vérifier cette signature sans avoir accès au hardware physique.

Ce mécanisme prouve deux choses : que le code s'exécute dans un TEE matériellement intègre, et que le code chargé est exactement celui déclaré (via son hash). Il ne prouve pas que ce code est correct, sûr ou exempt de vulnérabilités. Cette limite est fondamentale et constitue la source de la plupart des erreurs de raisonnement observées en production.

Sources : CCC Whitepaper v1.3 confidentialcomputing.io | Veraison framework documentation github.com/veraison/services

3.4 L'offre cloud actuelle

Les trois grands fournisseurs cloud proposent des offres commerciales basées sur les TEE depuis 2020-2023, ce qui marque le passage du stade de recherche au stade industriel :

- **Azure Confidential Computing** : VM confidentielles basées sur AMD SEV-SNP (série DCasv5, ECasv5) et Intel TDX. Azure Attestation Service pour la vérification à distance. Disponible en GA depuis 2022.
- **Google Cloud Confidential Computing** : Confidential VMs (AMD SEV-SNP) et Confidential GKE (nœuds Kubernetes confidentiels). Disponible en GA depuis 2020 pour les VMs.

- **AWS Nitro Enclaves** : Environnements d'exécution isolés basés sur Nitro Hypervisor, sans CPU TEE standard. Approche propriétaire différente de SGX/SEV-SNP/TDX.
- **Frameworks de portage** : Gramine (anciennement Graphene-SGX) et Occlum permettent de faire tourner des applications Linux non modifiées dans une enclave SGX, réduisant significativement le coût de portage.

Sources : Azure Confidential Computing docs — azure.microsoft.com | Google Confidential GKE — cloud.google.com | CNCF Confidential Containers — github.com/confidential-containers

4. Table des hypothèses

Le tableau suivant présente les trois hypothèses dans le format imposé par les consignes MVT. Les résultats et niveaux de confiance sont établis sur la base de l'analyse conduite aux sections 5, 6 et 7.

Hypothèse	Indicateur mesurable	Protocole de test	Résultat	Niveau de confiance
H1: Les TEE répondent à de vraies contraintes métier, indépendamment des seules obligations réglementaires	Proportion de cas d'usage métier vs conformité. Exemples d'adoption documentés indépendamment d'une obligation légale directe.	Analyse du retour d'expérience podcast (Anès Ayad, Net Protect) + revue des cas d'usage publiés par Azure, GCP, et dans la littérature académique (secteurs santé et finance).	Partiellement confirmée. Adoption métier réelle identifiée (authentification forte, données médicales). Souvent couplée à une contrainte réglementaire sous-jacente.	Moyen: Source principale : expert terrain (retour qualitatif). Biais possible vers les cas favorables. Manque de données quantitatives sur la proportion adoption métier seule vs adoption réglementaire.
H2: Les principaux freins à l'adoption sont la complexité d'intégration et le coût, davantage que les performances	Coûts identifiés (one-shot vs récurrent). Ratio coût TEE / coût déploiement standard. Overhead performance mesuré.	Retour terrain podcast (Anès Ayad) + benchmark ACM SIGMETRICS 2024 (Misono et al.) sur overhead performance. Distinction et comparaison coût intégration vs coût performance.	Confirmée. Coût one-shot + récurrent estimé à 2-3x un déploiement standard. Overhead performance secondaire selon retour terrain. Compatibilité matérielle identifiée comme frein complémentaire.	Élevé: Données qualitatives terrain confirmées par données quantitatives benchmark peer-reviewed (ACM SIGMETRICS 2024). Limite : ordre de grandeur 2-3x non publié, issu d'un seul praticien.
H3: Les enclaves mal implémentées ou non auditées créent une fausse confiance : le périmètre de menace se déplace, il ne disparaît pas	Vecteurs d'attaque résiduels documentés (CVE). Incidents prod liés à une mauvaise implémentation de l'attestation. Fréquence des erreurs de raisonnement.	Analyse des CVE publics (Foreshadow 2018, CacheOut 2020, SGAXe 2020) + retour terrain podcast sur les erreurs fréquentes en production + analyse du mécanisme d'attestation (CCC Whitepaper, Veraison).	Confirmée. Erreur de raisonnement fréquente selon l'expert terrain (périmètre déplacé, non supprimé). SGX protège contre l'hyperviseur, pas contre les CVE dans le code embarqué. Attestation non vérifiée = risque majeur.	Élevé: CVE publics peer-reviewed + confirmation terrain indépendante par un praticien. Limite : les CVE cités ont été patchés ; la fausse confiance marketing est documentée qualitativement, non quantitativement.

5. Hypothèse 1: Adoption métier versus obligation réglementaire

5.1 Le double moteur d'adoption

L'adoption du Confidential Computing est souvent présentée comme une réponse aux obligations réglementaires croissantes (RGPD, HDS, NIS2, PCI-DSS). Cette lecture est partielle. Elle ignore un second moteur d'adoption, indépendant de la contrainte légale : la valeur métier directe générée par des cas d'usage qui n'existaient pas avant les TEE, ou qui posaient des risques opérationnels inacceptables sans eux.

La question que pose H1 est précise : des organisations adopteraient-elles des TEE en l'absence totale d'obligation réglementaire ou contractuelle ? Le retour terrain de Net Protect, confirmé par les cas d'usage publiés par les fournisseurs cloud, apporte des éléments de réponse concrets.

5.2 Retour terrain : Net Protect

« On n'a pas de réponse réglementaire aujourd'hui. C'est plus au niveau des contraintes métier. On va appliquer et configurer les TEE dans certains cas et pour certains utilisateurs qui doivent manipuler des données sensibles ou à risque. » — Anès Ayad, CEO Net Protect, podcast MVT 2026

Net Protect intervient principalement dans deux secteurs : la finance et la santé. Dans le secteur financier, la mise en place de Windows Hello for Business via TEE répond à un besoin opérationnel direct : permettre une authentification forte par empreinte digitale sans dépendance à un flux cloud externe. Avant cette implémentation, la solution utilisée nécessitait une ouverture de flux vers un service cloud pour chaque authentification ce qui créait une dépendance réseau critique et des incidents en cas de coupure.

« Avant le TEE, on utilisait une solution qui demandait de faire une ouverture de flux sur un cloud pour s'authentifier, ce qui n'est pas pratique en cas de coupure de flux ou d'incident. » — Anès Ayad, podcast MVT 2026

Ce cas d'usage illustre une valeur métier directe : la résilience opérationnelle, indépendamment de toute obligation réglementaire spécifique à l'authentification biométrique. L'enclave permet de réserver une partie du processeur pour gérer l'authentification localement, en isolant les tentatives d'authentification et les données biométriques du reste du système.

5.3 Cas d'usage documentés indépendants de la conformité

Au-delà du retour terrain de Net Protect, plusieurs cas d'usage publiés illustrent une adoption motivée par la valeur métier :

- **Calcul collaboratif inter-organisations (Federated Learning confidentiel).** Plusieurs organisations entraînent un modèle de machine learning sur leurs données combinées sans révéler leurs données respectives. Les TEE permettent ce calcul sans recourir à des protocoles de calcul multi-parties cryptographiquement lourds (MPC classique). Ce cas d'usage génère une valeur métier directe accès à

des données impossibles à partager autrement indépendamment de toute obligation légale.

- **Traitement de données médicales sans exposition aux prestataires.** Un établissement de santé peut externaliser le traitement de données patients à un prestataire technique sans que ce prestataire ni même son infrastructure ne puisse accéder aux données en clair. Ce cas d'usage existe indépendamment de la réglementation HDS, même si celle-ci le renforce.
- **IA sur données financières confidentielles.** Une institution financière peut faire tourner des modèles d'analyse de risque sur des données clients sensibles dans un cloud tiers, avec la garantie technique que le fournisseur cloud ne peut pas accéder aux données. Ce cas est motivé par la compétitivité (accès à la puissance de calcul cloud) autant que par la conformité.

Sources : Azure Confidential Computing azure.microsoft.com | Google Confidential GKE cloud.google.com | Retour terrain : Anès Ayad, Net Protect (podcast MVT 2026)

5.4 La frontière floue entre métier et réglementation

H1 est partiellement confirmée. L'adoption métier existe de façon indépendante de la réglementation, mais les deux moteurs sont rarement totalement dissociés en pratique. Un établissement de santé adopte les TEE parce que ses données sont intrinsèquement sensibles ET parce que la réglementation HDS l'y incite. Un acteur financier adopte les TEE pour protéger ses données clients ET parce que PCI-DSS impose des garanties de confidentialité.

La vraie question n'est donc pas « réglementation ou métier ? » mais « lequel des deux est le déclencheur initial ? ». Le retour terrain de Net Protect suggère que, dans les cas observés, c'est la contrainte métier (données sensibles à manipuler, besoin de résilience opérationnelle) qui déclenche l'adoption, la conformité réglementaire venant ensuite la renforcer et la légitimer en interne.

Cette nuance est importante pour un Lead Dev : si l'unique justification d'un projet TEE est la conformité réglementaire, sans valeur métier identifiable, le rapport coût/bénéfice est probablement défavorable.

6. Hypothèse 2 — Les vrais freins : coût et complexité

6.1 Ce que la littérature dit sur les performances

La question des performances des TEE est souvent la première soulevée lors de l'évaluation d'un projet Confidential Computing. Le benchmark de référence sur ce sujet (Misono et al., ACM SIGMETRICS 2024) compare SGX, SEV-SNP et TDX sur des charges de travail représentatives en conditions réelles, sur les infrastructures cloud d'AWS, Azure et GCP. C'est à ce jour la comparaison la plus complète et la plus récente disponible dans la littérature peer-reviewed.

Source : Misono et al., ACM SIGMETRICS 2024 dl.acm.org/doi/10.1145/3700418

Les résultats sont différenciés selon le type de charge de travail :

- **Charges CPU pures (calcul scientifique, chiffrement, compression) :** overhead quasi nul sur SEV-SNP et TDX. Le chiffrement mémoire matériel n'impacte pas significativement les calculs purs. C'est l'argument commercial des fournisseurs cloud.
- **Charges I/O-intensives (bases de données, systèmes de fichiers, streaming) :** 30 à 50 % de latence supplémentaire sur SEV-SNP et TDX. Le chiffrement de chaque page mémoire à l'accès crée un goulot d'étranglement sur les charges avec beaucoup d'entrées/sorties.
- **Temps de démarrage (boot time) :** 2 à 5 fois plus long pour une VM confidentielle SEV-SNP vs VM standard. L'initialisation du contexte chiffré est coûteuse. Ce point est particulièrement pénalisant pour les architectures auto-scalantes ou les charges de type FaaS.
- **Cas particulier SGX v1 (EPC 128 Mo) :** dégradation massive sur les charges dépassant la limite EPC, en raison du swap chiffré vers la RAM normale. Ce point est documenté dans la spécification Intel SGX et confirmé par la revue IET 2024 (Feng et al.).

Sources : Intel SGX Developer Reference intel.com | Feng et al., IET 2024
ietresearch.onlinelibrary.wiley.com/doi/full/10.1049/cmu2.12759

6.2 Le vrai coût selon le retour terrain

« Il faut distinguer le coût one-shot, qui est l'intégration, et le coût récurrent, qui va être la maintenance. On peut dire qu'un TEE coûte deux à trois fois plus. » — Anès Ayad, CEO Net Protect, podcast MVT 2026

Anès Ayad distingue deux composantes du coût réel d'un déploiement TEE, indépendantes du coût de performance mesuré dans les benchmarks :

Coût one-shot (intégration)

Le portage d'une application existante dans un environnement enclave constitue le poste de coût le plus significatif. Pour SGX, ce portage implique l'identification des parties sensibles du code, leur extraction dans une enclave, la gestion des interfaces entre l'enclave et le monde extérieur (ecalls/ocalls), et la mise en place du flux d'attestation. Des frameworks comme Gramine ou Occlum réduisent ce coût en permettant l'exécution d'applications Linux non modifiées, mais ils introduisent leur propre surface d'attaque.

Pour SEV-SNP et TDX, le portage est plus simple (la VM entière est protégée) mais la configuration de l'attestation reste complexe : il faut mettre en place un service de vérification de quotes, gérer les certificats, et intégrer le flux de vérification dans l'application cliente.

Coût récurrent (maintenance)

La maintenance d'une enclave en production est plus lourde qu'une VM classique. Les mises à jour de microcode (TCB recovery) nécessaires après la découverte de vulnérabilités matérielles comme Foreshadow ou CacheOut forcent un renouvellement de l'attestation. Les enclaves doivent être recompilées, réauditées, et les certificats renouvelés. Ce cycle de maintenance est continu et nécessite une expertise sécurité dédiée.

Compatibilité matérielle

« Ça sera seulement une certaine gamme de laptops qui pourra permettre de supporter les TEE. Et également on réserve une certaine partie du CPU, ce qui veut dire que l'ordinateur va perdre en performance. » — Anès Ayad, podcast MVT 2026

Pour les déploiements sur postes de travail (cas de Net Protect), seuls les modèles de machines compatibles peuvent supporter les TEE. Cela contraint le déploiement à une sous-population du parc existant et génère un coût de renouvellement matériel que les évaluations initiales n'anticipent souvent pas.

6.3 L'argument décisionnel face à un DSI

« Mon principal argument pour vendre les TEE à un DSI, c'est le retour sur investissement. Je présente toujours le scénario de menace spécifique que le TLS ne couvre pas, par exemple, quelqu'un qui a réussi à s'infiltrer chez le cloud provider, et là, on sera protégé, puisque la communication a été chiffrée dans l'enclave. » — Anès Ayad, podcast MVT 2026

L'argument du retour sur investissement repose sur la démonstration d'un vecteur de menace spécifique que les mécanismes de sécurité classiques ne couvrent pas. Pour un DSI, la preuve n'est pas technique mais économique : le coût d'un incident de confidentialité en production (perte de données clients, sanctions réglementaires, atteinte à la réputation) versus le coût total d'intégration des TEE.

Cette approche suppose que le modèle de menace de l'organisation inclut explicitement un adversaire infrastructure, ce qui n'est pas toujours le cas et doit être établi avant de décider d'un déploiement.

6.4 Synthèse : comparaison des freins

Frein	Niveau d'impact	Concerne	Atténuations possibles
Coût d'intégration (one-shot)	Élevé: 2 à 3x un déploiement standard	Toutes organisations	Frameworks Gramine/Occlum pour SGX. Confidential Containers (CNCF) pour VM.
Coût de maintenance (récurrent)	Élevé: expertise sécurité dédiée requise	Organisations sans équipe sécurité	Externalisation de l'attestation (Azure Attestation Service, MAA).
Compatibilité matérielle	Moyen à élevé: renouvellement parc	Déploiements sur poste de travail	Planification sur cycle de renouvellement matériel habituel.
Overhead performance (I/O-intensif)	Moyen: 30 à 50 % sur I/O	Services base de données, streaming	SEV-SNP/TDX plutôt que SGX. Benchmarker le workload avant décision.
Overhead performance (CPU pur)	Faible: quasi nul sur SEV-SNP/TDX	Calcul scientifique, chiffrement	Pas d'atténuation nécessaire pour ces charges.
Overhead démarrage (boot time)	Élevé: x2 à x5	Architectures auto-scalantes, FaaS	Pré-démarrage des VMs confidentielles. Adapter l'architecture de scaling.

7. Hypothèse 3: Fausse confiance et déplacement du périmètre de menace

7.1 Ce que protège réellement un TEE

Un TEE protège contre un vecteur de menace précis : l'accès à la mémoire de l'enclave par un processus extérieur à cette enclave. Concrètement, un administrateur avec les droits root sur le serveur hôte ne peut pas lire le contenu de la mémoire d'une enclave SGX active. L'OS et l'hyperviseur ne voient qu'un espace chiffré dont ils n'ont pas la clé. C'est le cas d'usage central du Confidential Computing.

Ce que le TEE ne protège pas est tout aussi important à délimiter : les vulnérabilités dans le code embarqué dans l'enclave, les erreurs de configuration de l'attestation, les side-channels matériels exploitant le CPU lui-même, et les bugs dans les dépendances logicielles embarquées. Ces vecteurs restent entièrement ouverts, indépendamment de l'isolation matérielle.

7.2 Les vulnérabilités documentées de SGX

Trois attaques majeures publiées entre 2018 et 2020 ont démontré les limites de l'isolation matérielle de SGX et alimenté le débat sur la solidité réelle des TEE :

Foreshadow (2018, CVE-2018-3615)

Van Bulck et al. (USENIX Security 2018) ont démontré qu'en exploitant le mécanisme de prédiction de branchement spéculatif du CPU Intel, il était possible d'extraire des clés secrètes depuis une enclave SGX active. L'attaquant avait uniquement besoin d'un accès à l'OS hôte, pas d'accès physique au hardware. Cette attaque cible le CPU lui-même, pas l'enclave.

Source : CVE-2018-3615 Intel Security Advisory INTEL-SA-00161 | Van Bulck et al., USENIX Security 2018

CacheOut (2020, CVE-2020-0549)

Van Schaik et al. (IEEE S&P 2021) ont démontré qu'un attaquant avec accès à l'OS hôte pouvait lire des données depuis la mémoire cache L1 d'une enclave SGX en cours d'exécution, sans accès direct à l'enclave. La donnée « en cours d'utilisation » dans le cache CPU était accessible depuis l'extérieur de l'enclave.

Source : CVE-2020-0549 Van Schaik et al., IEEE S&P 2021 cacheoutattack.com

SGAxe (2020, CVE-2020-0551)

Des chercheurs ont démontré qu'un attaquant avec accès root sur le serveur hôte pouvait extraire la clé privée de signature d'attestation d'Intel depuis une enclave compromise. Avec cette clé, l'attaquant peut forger des rapports d'attestation valides prouver à un tiers distant qu'une enclave légitime s'exécute, alors qu'elle ne s'exécute pas. Intel a dû procéder à un renouvellement d'urgence de ses clés d'attestation (TCB recovery).

Source : CVE-2020-0551 SGAxe: How SGX Fails in Practice cacheoutattack.com/files/SGAxe.pdf

Ces trois attaques ont toutes été patchées et nécessitaient des conditions spécifiques (accès préalable à l'OS hôte, matériel non mis à jour). Elles ne remettent pas en cause le principe des TEE, mais elles délimitent précisément leur périmètre : un TEE

sur du matériel non maintenu, dans un environnement non audité, n'offre pas les garanties attendues.

7.3 L'erreur de raisonnement la plus fréquente en production

« Penser que mettre du code dans une enclave, c'est le sécuriser, mais pas du tout. C'est juste le périmètre de confiance qui est déplacé. On ne le fait pas disparaître. SGX protège contre un hyperviseur hostile, mais il ne protège pas des bugs dans le propre code. Il peut y avoir une CVE dans le code embarqué dans l'enclave. » — Anès Ayad, CEO Net Protect, podcast MVT 2026

Cette formulation, « le périmètre de confiance est déplacé, pas supprimé », est la contribution terrain la plus importante de cette veille. Elle exprime en une phrase la limite fondamentale des TEE que les communications marketing tendent à masquer.

Le mécanisme d'attestation ne fait qu'aggraver ce problème : il certifie que le bon code s'exécute dans une enclave intègre. Si ce code contient un bug, une backdoor ou une dépendance vulnérable, l'attestation certifie qu'un code défectueux s'exécute correctement dans une enclave, ce qui ne constitue en rien une garantie de sécurité.

7.4 Les risques opérationnels les plus fréquents

« Les risques les plus sous-estimés, ce sont les problèmes liés au CPU, la charge, la perte de performance, et les problèmes de sécurité liés à la non-vérification de l'attestation. » — Anès Ayad, podcast MVT 2026

Trois catégories de risques opérationnels ressortent du retour terrain et de la littérature :

- **Attestation non vérifiée ou non mise à jour après un patch microcode.** Si le client ne vérifie pas rigoureusement la quote d'attestation (signature, fraîcheur, mesure du code chargé), il accepte une enclave potentiellement compromise. Après un TCB recovery (renouvellement de clés suite à une CVE hardware), les enclaves non mises à jour présentent une attestation invalide qui peut être ignorée si la vérification est mal implémentée.
- **Fausse confiance générée par le marketing.** Le terme « Confidential Computing » suggère une confidentialité totale. Les organisations qui n'en comprennent pas les limites techniques déploient sans audit, avec la conviction (erronée) que l'enclave protège contre tous les vecteurs d'attaque.
- **Dépendances vulnérables dans l'enclave.** Le code embarqué dans une enclave SGX inclut souvent des bibliothèques tierces. Une CVE dans une dépendance embarquée expose les données de l'enclave, indépendamment de l'isolation matérielle. L'audit des dépendances dans l'enclave est une étape souvent négligée.
- **Seal keys et gestion des clés.** Les données chiffrées avec la seal key d'une enclave SGX sont perdues si l'enclave est recompilée (changement de la mesure) ou si le hardware change. Une migration mal planifiée peut rendre des données inaccessibles définitivement.

7.5 Les métriques de succès d'une enclave

« Moi, je donnerai trois métriques. Le premier, c'est le taux d'ouverture du code sensible dans l'enclave, logiquement, ce n'est pas la totalité de l'enclave. Également, on fera une certaine audite et le résultat de cette audite déterminera si ça remplit son rôle ou pas. Et le dernier, c'est l'absence de fuite de mémoire hors enclave. » — Anès Ayad, podcast MVT 2026

Ces trois métriques sont opérationnelles et directement vérifiables :

4. **Taux de code sensible dans l'enclave.** L'enclave ne doit contenir que le strict nécessaire. Un taux élevé (toute l'application dans l'enclave) augmente la surface d'attaque à l'intérieur de l'enclave et le risque de CVE dans le code embarqué.
5. **Résultat d'audit.** Une enclave non auditée par un tiers indépendant ne peut pas être considérée comme offrant les garanties du Confidential Computing. L'audit porte sur l'implémentation de l'attestation, la gestion des seal keys, et les dépendances embarquées.
6. **Absence de fuite mémoire hors enclave.** Vérifiable via des outils de monitoring de la mémoire et des tests de pénétration ciblés. Toute donnée sensible apparaissant en dehors de l'EPC constitue un incident de sécurité.

7.6 Le conseil terrain pour démarrer

« Le premier conseil : définir un modèle de menace, contre qui veut-on se défendre ? Le deuxième : commencer par l'attestation, pas par l'enclave. » — Anès Ayad, podcast MVT 2026

Ce conseil en deux étapes est structurant pour tout projet Confidential Computing. La définition du modèle de menace en premier lieu permet d'éviter de déployer des TEE pour des menaces qu'ils n'adressent pas. La maîtrise de l'attestation avant le déploiement de l'enclave permet d'éviter l'erreur la plus fréquente en production.

8. Table Claims/ Sources

Affirmation	Source primaire	Pourquoi crédible	Limites et biais
Les TEE protègent la donnée en cours d'utilisation (troisième état)	CCC Whitepaper v1.3 (nov. 2022) — confidentialcomputing.io	Référence Linux Foundation, citée dans tous les travaux académiques du domaine.	Source orientée promotion du CC. Définition large pouvant minimiser les limites.
Overhead TEE quasi nul sur CPU pur, 30-50 % sur I/O, boot x2 à x5 (SEV-SNP, TDX)	Misono et al., ACM SIGMETRICS 2024 — dl.acm.org/doi/10.1145/3700418	Benchmark peer-reviewed, multi-provider (AWS, Azure, GCP), données 2024, reproductible.	Charges de travail représentatives mais non exhaustives. Résultats dépendants de la config matérielle.
EPC limité à 128 Mo sur SGX v1, dégradation massive au-delà	Intel SGX Developer Reference — intel.com Feng et al., IET 2024	Spécification officielle Intel + revue académique récente.	SGX v2 améliore ce point. Moins pertinent pour les nouveaux déploiements.
Les side-channels CPU permettent d'extraire des données d'une enclave SGX active (Foreshadow, CacheOut)	CVE-2018-3615 (USENIX 2018) CVE-2020-0549 (IEEE S&P 2021)	CVE publics, papers peer-reviewed, confirmés et patchés par Intel.	Attaques patchées. Requièrent accès OS hôte et matériel spécifique non mis à jour.
SGAxe (2020) a permis de forger des rapports d'attestation SGX valides	CVE-2020-0551 — SGAxe: How SGX Fails in Practice — cacheoutattack.com/files/SGAxe.pdf	CVE public, paper peer-reviewed, réponse Intel (TCB recovery) confirme la vulnérabilité.	Patchée via TCB recovery. Requiert compromission initiale de l'enclave.
L'attestation prouve l'environnement d'exécution, pas la correction du code embarqué	CCC Whitepaper v1.3 + Veraison framework docs — github.com/veraison/services	Whitepaper de référence + projet open source CCC actif et maintenu.	Limite documentée mais parfois minimisée dans les communications marketing.
Un déploiement TEE coûte 2 à 3 fois plus qu'un déploiement standard	Retour terrain : Anès Ayad, CEO Net Protect — podcast MVT LeadDev 2026	Expert praticien, CEO cabinet spécialisé réseaux et sécurité, retour sur projets réels.	Donnée qualitative non publiée, ordre de grandeur issu d'un seul praticien. Non généralisable sans confirmation supplémentaire.
Le risque principal en production est la non-vérification de l'attestation après un patch microcode	Anès Ayad, podcast MVT 2026 CVE-2020-0551 (SGAxe)	Confirmation terrain + CVE documenté illustrant les conséquences d'une attestation compromise.	Fréquence non quantifiée dans la littérature académique. Retour terrain qualitatif.
Azure Confidential VMs, Google Confidential GKE et AWS Nitro Enclaves sont disponibles en production	Azure Confidential Computing — azure.microsoft.com Google Confidential GKE — cloud.google.com	Documentation officielle des deux fournisseurs cloud majeurs.	Sources potentiellement promotionnelles. Retours d'expérience production encore peu nombreux dans la littérature académique indépendante.

9. Contre-arguments

Trois objections sérieuses à l'adoption du Confidential Computing méritent d'être traitées en détail. Pour chacune, nous présentons la réponse et la condition qui nous ferait changer d'avis, conformément aux exigences de falsifiabilité des consignes MVT.

9.1 Les CVE prouvent que les TEE ont été compromis de façon répétée, la protection est illusoire

L'objection en détail. Foreshadow (2018), CacheOut (2020) et SGAXe (2020) montrent que les enclaves SGX ont été compromises de façon répétée par des chercheurs en sécurité. Si des laboratoires académiques ont réussi à extraire des données d'enclaves SGX, comment justifier le déploiement de cette technologie pour protéger des données sensibles en production ?

Réponse. Ces trois attaques partagent des caractéristiques communes qui délimitent leur portée pratique : elles ont toutes été découvertes dans un contexte de recherche académique, elles nécessitaient toutes un accès préalable à l'OS hôte (droits root ou équivalent), et elles ont toutes été patchées via des mises à jour de microcode. Sur du matériel post-2022 correctement maintenu, ces vecteurs d'attaque spécifiques ne sont plus exploitables dans les conditions décrites dans les papers.

Plus fondamentalement, ces attaques ne remettent pas en cause le principe des TEE, elles en délimitent le périmètre réel. Un TEE ne protège pas contre un attaquant qui exploite des side-channels matériels sur du hardware non maintenu. Il protège contre un accès mémoire direct par l'infrastructure. Ces deux menaces sont différentes, et le modèle de menace doit les distinguer explicitement.

Condition de falsification : on changerait d'avis si une exfiltration reproductible de données depuis une enclave TEE sur du matériel post-2023 correctement mis à jour (microcode à jour), sans droits root préalables sur l'OS hôte, était publiée et confirmée par des pairs dans un contexte peer-reviewed.

9.2 La conformité réglementaire est le seul vrai moteur d'adoption

L'objection en détail. Sans RGPD, HDS, NIS2 ou PCI-DSS, aucune organisation ne prendrait le risque de déployer une technologie aussi complexe et coûteuse. L'adoption du Confidential Computing est entièrement contrainte par la réglementation, pas choisie. Si la réglementation disparaissait demain, le marché s'effondrerait.

Réponse. Le retour terrain de Net Protect identifie des cas d'usage dont la valeur métier est indépendante de toute obligation réglementaire directe : l'authentification forte sans dépendance réseau répond à un besoin de résilience opérationnelle, pas de conformité. Le calcul collaboratif inter-organisations sur données sensibles crée une valeur économique directe (accès à des données impossibles à partager autrement) que les protocoles classiques ne permettent pas.

La réglementation joue certes un rôle d'accélérateur et de légitimation interne, mais elle n'est pas l'unique déclencheur. Des secteurs comme la défense, le renseignement ou la propriété intellectuelle industrielle ont des besoins de confidentialité qui précèdent et dépassent toute obligation légale.

Condition de falsification : on changerait d'avis si, après revue exhaustive de la littérature et des retours terrain d'un échantillon représentatif d'organisations utilisatrices, aucun cas d'adoption motivé uniquement par des contraintes métier (sans obligation réglementaire ou contractuelle) n'était documenté.

9.3 Le chiffrement classique (TLS + chiffrement au repos) est suffisant

L'objection en détail. TLS protège les données en transit. Le chiffrement AES-256 au repos protège les données sur disque. La combinaison des deux couvre 99 % des scénarios de menace réels. La complexité et le coût des TEE ne sont pas justifiés pour des organisations dont l'adversaire principal est un attaquant externe, pas leur propre fournisseur cloud.

Réponse. TLS et le chiffrement au repos ne protègent pas la donnée pendant son traitement en mémoire. Cette limite est précise et documentée : un snapshot de la mémoire vive d'une VM en cours d'exécution contient les données en clair. Un administrateur cloud avec les droits adéquats peut effectuer ce snapshot. Un hyperviseur compromis peut accéder à la mémoire de toutes les VMs qu'il orchestre.

L'objection est valide pour les organisations dont le modèle de menace n'inclut pas d'adversaire infrastructure. Pour celles dont le modèle de menace inclut cet adversaire, secteur de la santé, finance, défense, cloud souverain, les TEE sont le seul mécanisme technique disponible pour protéger la donnée dans ce troisième état.

Condition de falsification : on changerait d'avis si un mécanisme cryptographique sans matériel dédié (purement logiciel) permettait de protéger la donnée en mémoire pendant son traitement avec des garanties équivalentes aux TEE et des performances comparables à TLS.

10. Conclusion opérationnelle

10.1 Synthèse des résultats

Sur H1 (adoption métier). Partiellement confirmée. Les TEE répondent à des besoins métier réels qui précèdent ou dépassent les obligations réglementaires : résilience opérationnelle (authentification sans dépendance cloud), traitement de données médicales sans exposition aux prestataires, calcul collaboratif inter-organisations. La frontière avec la conformité réglementaire est floue en pratique, mais le moteur métier existe de façon indépendante.

Sur H2 (freins et coûts). Confirmée. Le coût d'intégration (one-shot) et de maintenance (récurrent) est estimé à 2 à 3 fois un déploiement standard. L'overhead de performance sur les charges I/O-intensives (30-50 %) est réel mais secondaire par rapport au coût opérationnel. La compatibilité matérielle constitue un frein complémentaire pour les déploiements sur parc existant. Le frein principal n'est pas technique mais économique et organisationnel.

Sur H3 (fausse confiance). Confirmée. Les enclaves mal implémentées ou non auditées créent une fausse confiance documentée. Le périmètre de confiance se déplace vers l'attestation, les dépendances embarquées et la gestion des clés, il ne disparaît pas. L'erreur de raisonnement la plus fréquente (« mettre du code dans une enclave le sécurise ») est confirmée par le retour terrain et documentée par les CVE.

10.2 Tableau de décision

Situation	Décision	Justification	Condition préalable
Modèle de menace inclut un adversaire infrastructure (fournisseur cloud, admin hôte, hyperviseur)	Déployer — SEV-SNP ou TDX	Seul mécanisme disponible pour ce vecteur. Overhead acceptable sur CPU pur.	Audit obligatoire de l'attestation. Expertise sécurité dédiée.
Cas d'usage impossible sans TEE (calcul collaboratif, données médicales sans exposition prestataire)	Déployer avec budget intégration + maintenance dimensionné dès le départ	Valeur métier directe. Coût 2-3x justifié par l'impossibilité de l'alternative.	Identifier et minimiser le périmètre de code dans l'enclave.
Adoption motivée uniquement par la conformité, sans valeur métier identifiée	Évaluer les alternatives d'abord	Chiffrement applicatif, Zero Trust, HSM peuvent couvrir le besoin à moindre coût.	Formaliser le modèle de menace avant toute décision.
Déploiement sans expertise sécurité dédiée, sans audit de l'attestation	Ne pas déployer	Risque de fausse confiance. Une attestation non vérifiée expose autant qu'une absence de TEE.	Former l'équipe ou externaliser l'audit avant tout déploiement.
Charge I/O-intensive avec SLA < 100 ms	Benchmarker avant de décider	Overhead 30-50 % peut casser les SLA. Résultat dépend du workload spécifique.	Reproduire le benchmark sur le workload réel, pas sur des charges génériques.

10.3 Ce que cette veille n'a pas pu établir

Plusieurs questions restent ouvertes à l'issue de cette veille :

- La proportion exacte d'adoption purement métier vs adoption réglementaire n'a pas pu être quantifiée. Notre retour terrain est qualitatif et limité à un praticien.
- L'ordre de grandeur du coût (2-3x un déploiement standard) est issu d'un seul expert terrain et n'a pas été confirmé par la littérature académique.
- L'impact réel des patches post-2022 sur les vecteurs Foreshadow/CacheOut/SGAxe n'a pas été testé expérimentalement dans notre démo.
- La comparaison entre les trois grandes implémentations (SGX vs SEV-SNP vs TDX) sur notre démo spécifique reste à documenter.

10.4 Perspectives

Le Confidential Computing est une technologie en cours d'industrialisation. Plusieurs évolutions sont à surveiller :

- **RISC-V et Keystone.** Des TEE open source basés sur RISC-V (projet Keystone) éliminent la dépendance à un constructeur unique (Intel/AMD). Cela réduit le risque de backdoor hardware et ouvre la voie à des audits indépendants de l'implémentation matérielle.
- **Confidential Containers (CNCf).** Le projet Confidential Containers de la CNCf industrialise le déploiement de conteneurs confidentiels sur Kubernetes, réduisant le coût de portage à quelques paramètres de configuration.
- **Post-quantum et TEE.** L'émergence de la cryptographie post-quantique posera de nouvelles questions sur la solidité des mécanismes d'attestation actuels, basés sur des algorithmes (RSA, ECDSA) potentiellement vulnérables à un adversaire quantique.
- **Régulation et certification.** L'évolution de NIS2 et des référentiels de certification (ANSSI, BSI) vers une exigence de protection de la donnée en cours d'utilisation accélérera probablement l'adoption dans les secteurs régulés.

11. Sources primaires

Réf.	Source	Lien / localisation
[1]	CCC Whitepaper v1.3 (nov. 2022) — Confidential Computing Consortium / Linux Foundation	confidentialcomputing.io/wp-content/uploads/sites/10/2023/03/CCC_outreach_whitepaper_updated_November_2022.pdf
[2]	Misono et al. — Benchmarking Confidential Computing on Cloud (ACM SIGMETRICS 2024)	dl.acm.org/doi/10.1145/3700418
[3]	CVE-2018-3615 — Foreshadow / Van Bulck et al., USENIX Security 2018 / Intel Advisory INTEL-SA-00161	intel.com/content/www/us/en/security-center/advisory/intel-sa-00161.html
[4]	CVE-2020-0551 — SGAXe: How SGX Fails in Practice (2020)	cacheoutattack.com/files/SGAXe.pdf
[5]	CVE-2020-0549 — CacheOut / Van Schaik et al., IEEE S&P 2021	cacheoutattack.com
[6]	Intel SGX Developer Reference & Overview — Intel Corporation	intel.com/content/www/us/en/developer/tools/software-guard-extensions/overview.html
[7]	Feng et al. — Survey on TEE Security (IET Information Security, 2024)	ietresearch.onlinelibrary.wiley.com/doi/full/10.1049/cmu2.12759
[8]	Veraison Framework Documentation — CCC / CNCF	github.com/veraison/services
[9]	CNCF Confidential Containers — projet officiel	github.com/confidential-containers
[10]	Azure Confidential Computing — Microsoft Documentation	azure.microsoft.com/en-us/solutions/confidential-compute
[11]	Google Confidential GKE — Google Cloud Documentation	cloud.google.com/confidential-computing
[12]	Gramine (LibOS SGX) — Documentation officielle	gramineproject.io
[13]	CNCF Keystone — TEE open source RISC-V	github.com/keystone-enclave/keystone
[14]	Anès Ayad — CEO & Fondateur, Net Protect Interview podcast MVT LeadDev 2026 (18 min)	Fichier : /podcast/podcast_episode.mp3 — voir /podcast/show_notes.md